Limiting Domain Controller Attack Surface: Why less services, less software, less agents = less exposure.

trimarcsecurity.com/hub-post/limiting-domain-controller-attack-surface-why-less-services-less-software-less-agents-less-expo

Scott Blake October 8, 2024

Updated: Dec 13, 2024



You should be able to count additional DC software installations on one AI generated computer hand.

Before we dive in, let's get all the Trimarc Certified Absolutes out of the way:

1. **All software presents some level of inherent risk.**
2. **Only required software that cannot live on other systems should be installed on Domain Controllers.**
3. **DCs should have a separate, detailed approval process for software/services/agents.**

Each organization’s needs and risk appetite will be different, but it is important to highlight that having less “stuff” on Domain Controllers (DCs) can lower the security risk to these critical systems by minimizing their attack surface.

At Trimarc, we have assessed hundreds upon hundreds of AD forests over the years while performing our Active Directory Security Assessment. Too often we discover questionable software running on DCs or the reluctance to acknowledge that the patch management team is effectively Tier 0 with their elevated rights through the patching agent. This article

is intended to be a guide to making the best-informed decisions through awareness of the potential issues and ensuring companies are asking the right questions.

There is no debate that securing Domain Controllers, and therefore Active Directory (AD), is of the utmost importance for any organization. These Windows servers host Active Directory Domain Services and control who can authenticate to and access resources within an organization. While there are best practice configurations for items like User Rights Assignments and Security Options, we wanted to highlight and emphasize how software allowed to run on a DC can be just as important (or detrimental!) to the security of Active Directory.

These items often introduce additional exposure that may get overlooked during deployment and are typically forgotten about for the full life of the DC. For example, a single agent running on all Domain Controllers can perform its own Denial of Service (DoS) against AD; it's happened before and will happen again.

Note: While this article is directed at Domain Controllers, this is also applicable to other Tier 0 systems (Entra Connect, AD CS, etc.) to a somewhat lesser degree.

Common types of agents/software on Domain Controllers include:

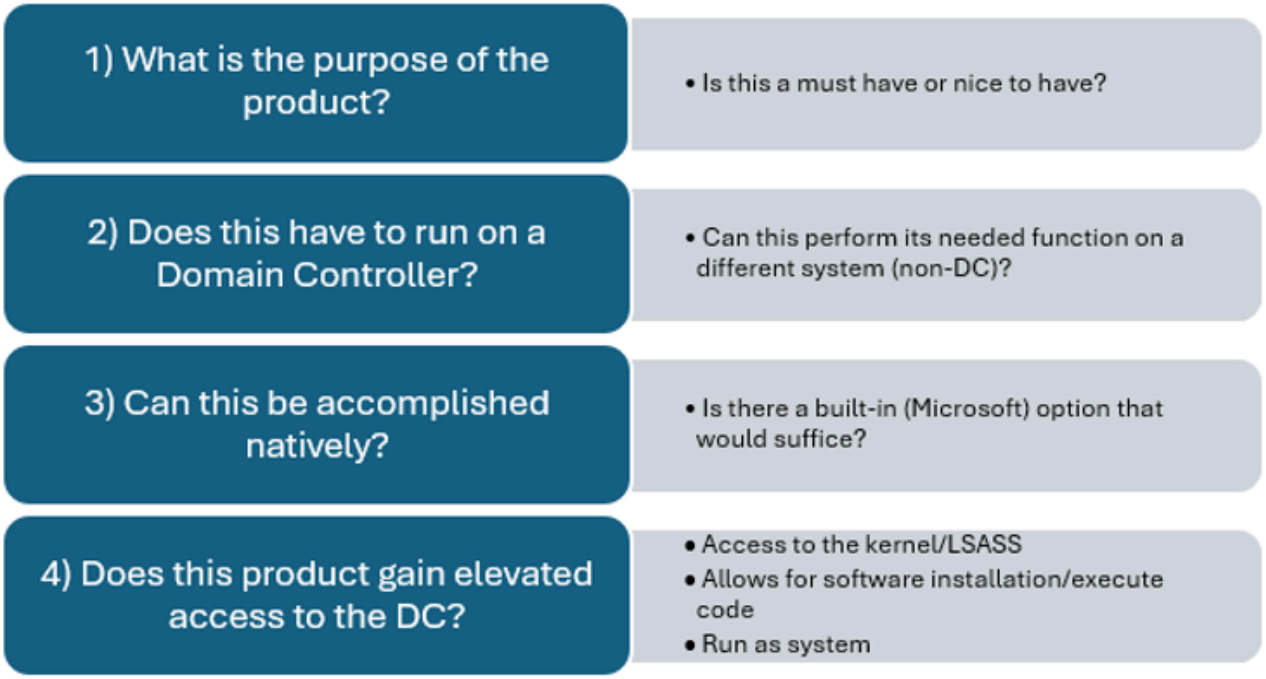
- Anti-Virus (AV)
- Endpoint Detection & Response (EDR/XDR/MDR)
- Identity Security Agents (MDI, etc.)
- Inventory
- Logging
- Management
- Monitoring
- Patching
- Vulnerability

Approval Process

Let's start with an assumption (always dangerous) that there is already a process for approving software installations on systems. This policy should include a separate approval procedure specifically targeted at Domain Controllers and other Tier 0 systems. To state the obvious, these systems matter more, and all additions should be thoroughly

vetted. It is also imperative that the additional risk (it's there!) is documented to include any mitigating controls.

The following basic questions should be asked during the approval, in some form:



Use the answer key below as a decision-making guide:

- If it is only a "NICE TO HAVE", consider not having it.
- If the answer to question 2 is "NO", do not put it on a Domain Controller, plain and simple. Less stuff = less exposure.
- If the answer to question 3 is "NATIVELY", consider using the native option.
- If the answer to question 4 is "YES", our frenemy "Risk Acceptance" enters the equation.

Trimarc Tip: DCs should NOT be deployed from a standard server template/image if it includes additional software components.

Risk & Risk Acceptance

To make intelligent and informed decisions through the approval process, an understanding of risk acceptance is required. For the purposes of this article, and to keep things simple, let's define risk acceptance as **the function gained outweighs the increased exposure.**

(Remember, with additional "stuff", there is always increased risk/exposure.)

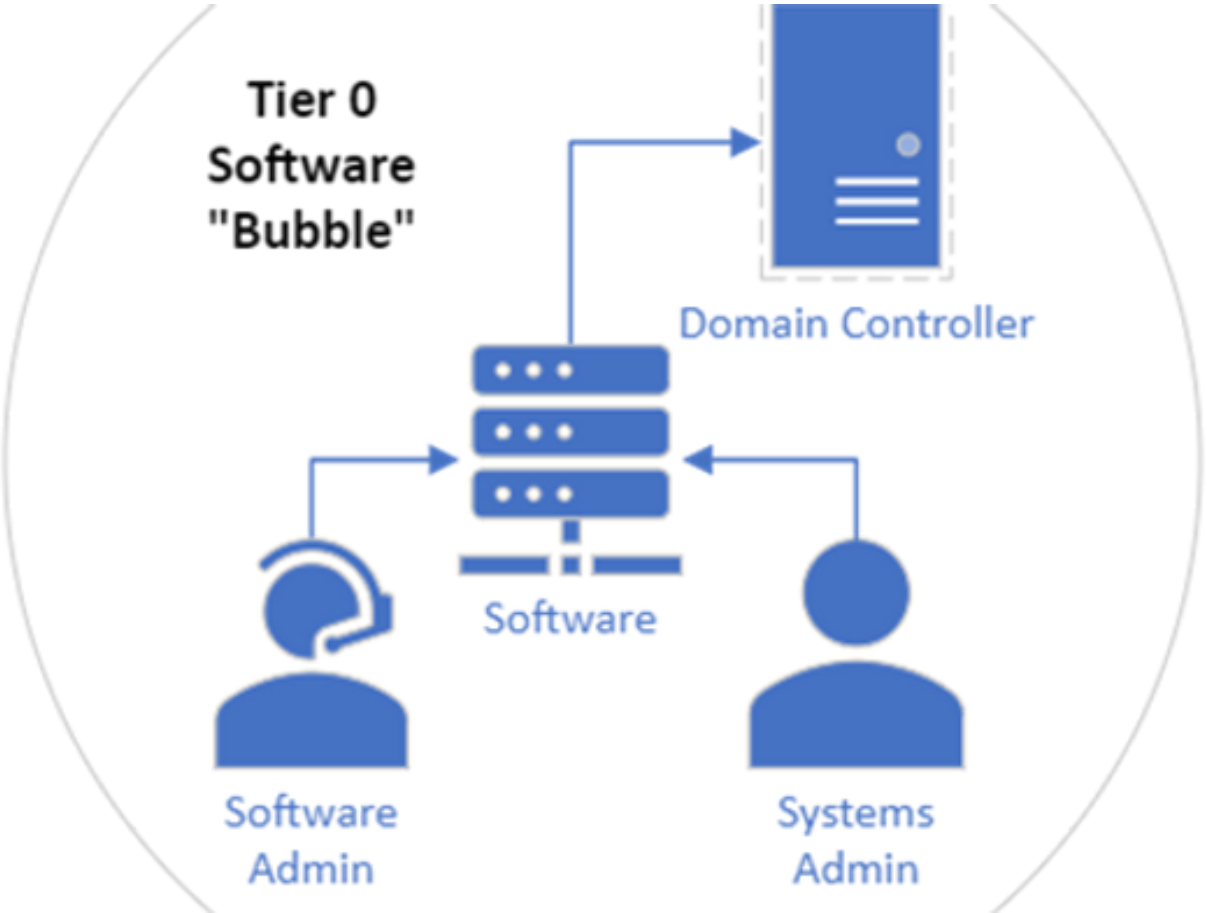
But what are all the factors at play? This is where many organizations fall flat in their approval process. They look at the software vendor and say, "*I trust this vendor, therefore I trust the software*" or "*this agent provides functionality for x*" without ever looking at the additional exposure that comes with the installation.

While these are valid indicators of trustworthiness and functionality, stopping there would be woefully short of a true risk acceptance determination. Before veering into a Risk Acceptance diatribe, let's bring this back to Domain Controllers. Consider the following points when deciding for your DCs:

Who Has Control?

If the software, services, agents have elevated rights (see "Rights required for the software" below) to DCs congrats:

- The software system is now considered Tier 0
- The administrators of the software are Tier 0
- The administrators of that system, you guessed it, are Tier 0



Note: Don't forget to set up separate Tier 0-specific systems (including separate administrative accounts) for managing your critical assets.

How is the software maintained?

- Updating may require a manual process.
- Consider NOT being on the latest/greatest release (n-1) unless it presents a security risk (there's that risk word again).

Rights required for the software.

Each of these items involve additional risk:

- Service runs as SYSTEM
- Service runs with Active Directory admin account privileges
- Installs/runs code
- Involves a kernel driver
- Interacts ("hooks") LSASS

The Recovery Process

If the software goes belly-up it could potentially bring down DCs breaking all functionality within the environment (assuming all DCs have the software).

Trimarc Tip: Scan and review software/services/agents on all DCs on a yearly basis. Ensure the product is still required and is running a recent version.

Trimarc recommends limiting software on Domain Controllers to the following systems:

- Antivirus (Microsoft Defender is included on Windows Operating Systems)
- Backup (Windows Server Backup is excellent and free)
- Event log collection (don't forget Windows Event Forwarding is an option)
- Identity security (ex. Microsoft Defender for Identity)
- Vulnerability scanning

Trimarc Tip: Notice that patch management is not included in this list? Trimarc recommends using WSUS for all Tier 0 systems to simplify the update process without needing a dedicated, Tier 0 patch management deployment. Note this recommendation may change based on Microsoft deprecating WSUS but it is still a viable option for Windows Server 2025.

Summary

It is critical to ensure that software installed on Domain Controllers is limited to the bare necessities. Anything more than the absolute minimum may tilt the function vs exposure equation in the favor of a potential attacker. Domain Controllers should only be viewed as a commodity – they should be easily replaced if there are issues, so there should never be anything “special” running on a Domain Controller that needs additional servicing.

There will always be an increase in risk with any software installation, but restricting the software on Domain Controllers to only what is required is the best way to reduce the risk of impact to confidentiality, integrity, and availability (the C.I.A. triad). This leads into a defense-in-depth approach coupled with a tried-and-true recovery process. But those are topics for another day and maybe another article or two.